

ComplyScan

How ComplyScan connects repository evidence to the EU AI Act, supports voluntary NIST assessment, and hands unresolved legal context to the right owner.

Core proposition: ComplyScan determines what an AI codebase can demonstrate against selected technical requirements. It does not classify the system, decide that legislation applies, or certify compliance.

How legal requirements are applied

1. Versioned source mapping Selected provisions become bounded technical objectives.	2. Evidence collection Code, tests, configuration, CI and infrastructure are examined.	3. Checked conclusion Cited evidence becomes developer work or a legal-team unknown.
--	--	--

EU AI Act technical coverage

The current pack covers 13 code-oriented objectives across Articles 9, 10, 12, 14, 15 and 50 of Regulation (EU) 2024/1689. Articles 9-15 are screened in the context of potentially high-risk systems; Article 50 transparency conditions are screened separately.

Article	Legal focus	What ComplyScan can evidence in the repository	What still needs legal or operational review
Article 9	Risk management	Risk-control tests, safety evaluations, validation of known failure or hazard conditions.	Lifecycle process, complete risk identification, fundamental-rights analysis and proportionality.
Article 10	Data and data governance	Dataset schema, completeness and quality checks; automated bias or fairness evaluation.	Representativeness, lawful data use, suitability, provenance and governance in practice.
Article 12	Record-keeping	Structured AI event logging and repository-controlled retention or expiry settings.	Production enablement, completeness, integrity, access and legally appropriate retention.
Article 14	Human oversight	Approval gates, override or intervention paths, and safe-stop or disable controls.	Reviewer authority, competence, availability and effective use in production.
Article 15	Accuracy, robustness and cybersecurity	Performance thresholds, fault handling, fallback tests and AI-specific security controls.	Suitability of metrics, real-world effectiveness, threat modelling and lifecycle consistency.
Article 50	Transparency	AI-interaction notices and machine-readable marking or provenance for synthetic content.	Applicable duty, organisational role, exceptions, prominence and technical feasibility.

Evidence boundary: A match is candidate technical evidence, not proof that a control is reachable, enabled, effective or legally sufficient. No detected evidence is not proof that implementation is absent.

From repository scan to legal handoff

A simple developer workflow produces an auditable technical record without asking engineers to make legal classifications.

1 SET UP	2 SCAN	3 ACT	4 HAND OFF
The developer selects EU AI Act and/or voluntary NIST mappings, plus a model provider for standard scans.	Local checks find technical signals. The approved model examines selected code with checked citations.	The short report gives developers concrete changes, evidence locations and completion criteria.	The JSON evidence bundle carries complete mappings and unknowns into legal review or the dashboard.

What the user receives

Human-readable report: a short result, up to three developer actions, completion criteria, code evidence, relevant EU or NIST context, demonstrated safeguards and questions for product or compliance. **Structured evidence bundle:** complete framework mappings, citations, action lifecycle, scan coverage and provenance for dashboards and due diligence.

Optional voluntary NIST AI RMF mapping

Users may select the **NIST AI Risk Management Framework** alongside or instead of the EU mapping. NIST results are always labelled voluntary recommendations - never legal obligations.

The current NIST technical pack covers dataset validation, human oversight, performance criteria, production monitoring, robustness, AI security, fairness, incident recovery, deactivation, third-party model monitoring, and appeal or override mechanisms across selected MAP, MEASURE and MANAGE practices.

How to interpret results

Result	Meaning
Demonstrated	Relevant implementation was found with checked code citations; this is not proof of legal compliance.
Incomplete	Part of the mechanism exists, but additional implementation or testing appears necessary.
Not demonstrated	The reviewed code did not establish the mechanism; this is not proof that it is absent elsewhere.
Unclear	Repository evidence or legal context was insufficient for a technical conclusion.
Needs product or compliance input	Applicability depends on deployment, organisational or legal facts that code cannot establish.

Who decides what

Developer Runs the scan and implements concrete code or configuration actions.	ComplyScan Finds and validates technical evidence, then maps it to selected provisions and practices.	Legal / compliance Determines scope, high-risk status, legal role, applicable duties, proportionality and evidence sufficiency.
--	---	---

Normal commands: `complyscan setup` selects the provider/model and technical mappings; `complyscan scan` produces `.complyscan/reports/latest.md` and the dashboard-ready `latest.json`.

Primary sources: [Regulation \(EU\) 2024/1689](#) and the [NIST AI Risk Management Framework](#). This document describes ComplyScan's technical evidence mapping and is not legal advice.